

# ACTIVIDAD 01

## ANÁLISIS Y PLANIFICACIÓN DEL PENTEST

**Caso:** Aurora Market

**Programa:** Hacker Women Council · Ethical Hacking

**Nombre:** Mariana Ponce Sepulveda

### 1. OBJETIVO DEL PENTEST

#### Objetivo 1

Identificar vulnerabilidades de seguridad en la aplicación web de Aurora Market que puedan permitir accesos no autorizados a información o funcionalidades.

#### Objetivo 2

Verificar los mecanismos de autenticación, autorización y control de acceso entre las diferentes cuentas y tipos de usuarios.

#### Objetivo 3

Evaluar el impacto de las vulnerabilidades encontradas y proponer medidas de seguridad para reducir los riesgos sin afectar la información ni disponibilidad de los clientes.

## **2. ALCANCE**

### **SÍ SE EVALUARÁ**

- Aplicación web de Aurora Market.
- Mecanismos de autenticación y gestión de sesiones.
- Control de acceso entre cuentas y tipos de usuarios.
- Gestión y consulta de información de clientes.
- Funcionalidades relacionadas con productos y pedidos.
- Validación de entradas y manejo de información dentro de la aplicación.

### **FUERA DEL ALCANCE**

- Redes sociales de Aurora Market.
- Proveedores y servicios de terceros.
- Cuentas de correo electrónico.
- Equipos o dispositivos de empleados.
- Sistemas o infraestructura no autorizada.
- Pruebas de ingeniería social.
- Acciones que puedan interrumpir el servicio o afectar información real.

### 3. AUTORIZACIÓN Y CONDICIONES

#### Permisos requeridos

1. Autorización formal y escrita de Aurora Market para realizar el pentest.
2. Definición y aprobación del alcance de la evaluación.
3. Cuentas de prueba para los diferentes tipos de usuarios.
4. Autorización para evaluar las funcionalidades incluidas dentro del alcance.
5. Designación de un contacto responsable de Aurora Market para comunicar incidentes o situaciones críticas.

#### Condiciones acordadas

1. Las pruebas se realizarán únicamente sobre la aplicación web autorizada.
2. No se realizarán pruebas contra redes sociales, proveedores, correos o sistemas de terceros.
3. No se realizarán acciones que puedan interrumpir deliberadamente la disponibilidad del servicio.
4. Se evitará modificar, eliminar o extraer información real de los clientes.
5. Las pruebas se realizarán durante horarios previamente acordados.
6. Las vulnerabilidades encontradas serán documentadas y reportadas de forma responsable.

### 4. TIPO DE PENTEST

#### ■ BLACK-BOX

Se selecciona la modalidad Black-box porque el equipo de Ethical Hacking cuenta con información técnica limitada sobre Aurora Market. No se dispone inicialmente de información detallada sobre la arquitectura, código fuente o tecnologías internas de la aplicación. La evaluación permitirá analizar la seguridad desde la perspectiva de un atacante externo, utilizando únicamente la información y accesos autorizados por la empresa.

## 5. PLANIFICACIÓN DEL PENTEST

| Elemento           | Plan                                                                                                      |
|--------------------|-----------------------------------------------------------------------------------------------------------|
| Objetivos          | Identificar y validar vulnerabilidades, especialmente en autenticación, autorización y control de acceso. |
| Alcance            | Aplicación web autorizada y sus funcionalidades de usuarios, sesiones, productos y pedidos.               |
| Permisos           | Autorización formal, alcance definido, cuentas de prueba y contacto responsable.                          |
| Metodología        | OWASP Web Security Testing Guide (WSTG).                                                                  |
| Información previa | Funcionalidades, tipos de usuarios, autenticación, sesiones y puntos de entrada autorizados.              |
| Recursos           | Equipo de pruebas, navegador, herramientas de análisis web, cuentas de prueba y registro de evidencias.   |
| Programación       | Pruebas coordinadas con Aurora Market y preferentemente durante horarios de menor actividad.              |

## 6. FASES DEL PENTEST

### 1. Reconocimiento

Recopilar información sobre la aplicación web autorizada, sus funcionalidades, tipos de usuarios, mecanismos de autenticación y posibles puntos de entrada.

### 2. Análisis de vulnerabilidades

Analizar la aplicación en busca de posibles vulnerabilidades relacionadas con autenticación, autorización, gestión de sesiones, control de acceso, validación de entradas y exposición de información.

### 3. Explotación

Validar de manera controlada las vulnerabilidades identificadas para comprobar su existencia y determinar su impacto, evitando afectar la disponibilidad del servicio o modificar información real.

### 4. Post-explotación

Determinar el impacto de las vulnerabilidades confirmadas y recopilar únicamente la evidencia necesaria para demostrar el riesgo.

### 5. Informe

Documentar las vulnerabilidades encontradas, evidencias, impacto, nivel de riesgo y recomendaciones de seguridad.

## 7. INVESTIGACIÓN

### Metodología seleccionada: OWASP Web Security Testing Guide (WSTG)

El OWASP Web Security Testing Guide (WSTG) es una guía de referencia para realizar pruebas de seguridad en aplicaciones web y servicios web. Proporciona un marco de buenas prácticas para estructurar evaluaciones de seguridad de forma sistemática. Entre sus categorías se encuentran recopilación de información, gestión de identidades, autenticación, autorización, gestión de sesiones, validación de entradas, manejo de errores y lógica de negocio.

#### ¿Por qué es útil para Aurora Market?

Esta metodología es adecuada porque el alcance del pentest se concentra en una aplicación web. Además, el posible acceso de un usuario a información perteneciente a otra cuenta hace especialmente importante evaluar los mecanismos de autenticación, autorización y control de acceso. Estas áreas forman parte de las pruebas contempladas por el WSTG.

#### Aplicación al caso

- **Autenticación:** verificar cómo la aplicación comprueba la identidad de los usuarios.
- **Autorización:** comprobar que cada usuario solamente pueda acceder a los recursos que le corresponden.
- **Gestión de sesiones:** revisar los controles relacionados con las sesiones de usuario.
- **Validación de entradas:** analizar cómo la aplicación procesa los datos proporcionados por los usuarios.
- **Lógica de negocio:** identificar comportamientos que puedan permitir utilizar las funcionalidades de una forma no prevista.

## CONCLUSIÓN

La planificación previa permite realizar una evaluación de seguridad de manera controlada, ética y alineada con los objetivos de Aurora Market. Debido al posible acceso de un usuario a información perteneciente a otra cuenta, se dará especial atención a los mecanismos de autenticación, autorización y control de acceso. Todas las pruebas deberán realizarse dentro del alcance autorizado, evitando afectar la disponibilidad del servicio o la información real de los clientes.

## Fuente

OWASP Foundation. **Web Security Testing Guide (WSTG)**.